

CO1

Assessment

Tool - 03

Name : A. Bharya

Reg no : 192424417

Course code : ITA1408

Course Name : Ethical Hacking

You report a vulnerability to a company through their official bug bounty program, but the company threatens legal action against you instead of paying the promised reward, claiming you "exceeded authorized scope." Discuss the disclosure and legal risks researchers face, and how to mitigate them beforehand.

Researchers participating in bug bounty programs can still face legal and ethical challenges, especially if there is a disagreement about whether their testing stayed within the program's authorized scope.

Disclosure and legal risks:

1. Scope disputes

Every bug bounty program defines specific targets that researchers are allowed to test. These targets may include websites, applications, APIs, or domains. If a researcher accidentally tests systems outside the scope, legal notices may be issued.

2. Unauthorized Access Claims

- Accessing systems beyond permission may violate cybersecurity laws.

Good intentions do not always protect researchers legally.

• Organizations may claim the researcher exceeded authorization.

• This can result in legal investigations or penalties.

3. Loss of Bug Bounty Reward

• Companies may refuse to pay the reward if program rules are violated.

• Reports may be marked as invalid.

• Rewards can be cancelled due to out-of-scope testing.

4. Civil or Criminal Legal Action

• If testing causes damage or affects users, the company may take legal action.

• Researchers may face civil lawsuits or criminal charges depending on others.

5. Program Disqualification

• The researcher may be removed from the bug bounty program.

• Future participation in the company's programs may be restricted.

• The report may be permanently rejected.

6. Service Disruption Liability

• Testing may accidentally cause server crashes or

• Business operations may be interrupted.

• The researcher may be held responsible for the damage caused.

How to Mitigate these risks:

1. Read the Bug Bounty Policy Carefully
 - Understand the scope, rules, prohibited activities, and reward criteria before testing.
2. Stay within the Authorized scope.
 - Test only the domains, applications, which were approved.
 - Avoid testing systems that are out of scope.
 - Stop testing if uncertain.
3. Obtain Written Clarification
 - Contact the company if the scope is unclear.
 - Request written permission before testing additional assets.
 - Keep copies of all communications.
4. Maintain proper Documentation
 - Save screenshots of the testing process.
 - Record logs and timestamps.
 - Preserve email conversations and reports.
5. Follow Responsible Disclosure
 - Report vulnerabilities through the official bug bounty portal.
 - Keep vulnerability details Confidential.

- Do not publicly disclose the vulnerability until the company has fixed it or given permission.

6. Avoid Accessing sensitive data or disrupting services.

- Do not view, copy, modify or delete confidential information.

- Avoid testing methods that could crash systems or interrupt business operations.

7. Follow safe Harbor policy and Applicable Laws.

- Comply with the program's Safe Harbor policy, if available.

- Follow cybersecurity, privacy, and data protection laws to reduce legal risks and ensure ethical behaviour.

Conclusion :-

Big bounty programs help improve cybersecurity by encouraging responsible vulnerability reporting. Researchers should always follow the program rules, stay within the authorized scope, and practice responsible disclosure. This helps avoid legal issues and protects both the researcher and the organization.